第5小时

信息安全技术基础知识

5.0 章节考点分析

第 5 小时主要学习信息安全基础知识、信息安全系统的组成框架、信息加解密技术、密钥管理技术、访问控制及数字签名技术、信息安全的抗攻击技术、信息安全的保障体系与评估方法等内容。

根据考试大纲，本小时知识点会涉及单项选择题，约占 5 分。本小时内容侧重于概念知识，根据以往全国计算机技术与软件专业技术资格(水平)考试的出题规律，考查的知识点多来源于教材，扩展内容较少。本小时知识架构如图 5.1 所示。

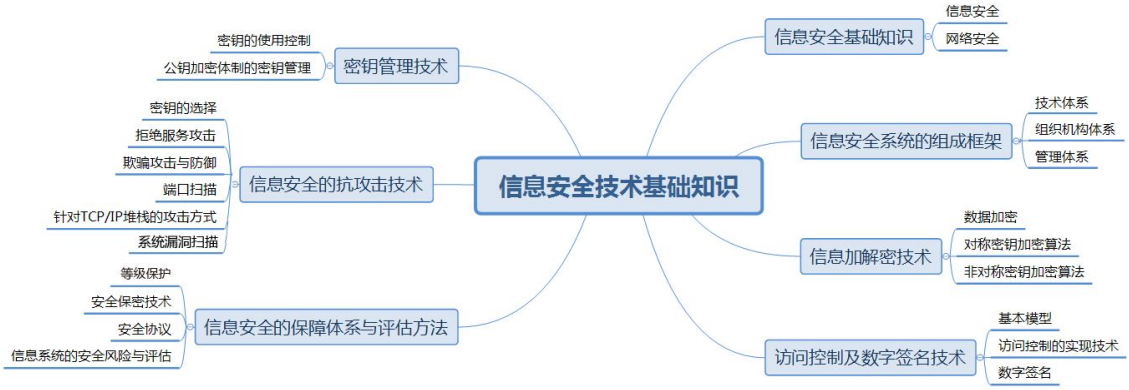

图 5.1 本小时知识架构

【导读小贴士】

信息安全事关国家安全和社会稳定，在新版教材中，信息安全的内容大幅增加了，知识点也得到了更新，与信息安全工程师的某些内容同步。所以掌握本小时知识点非常重要，不仅可以在考试中拿到分数，也会给日常生活带来帮助。

5.1 信息安全基础知识

【基础知识点】

（1）信息安全（Information Security）。信息安全是指为数据处理系统而采取的技术的和管理的安全保护，保护计算机硬件、软件、数据不因偶然的或恶意的原因而遭到破坏、更改和泄露。信息安全的基本要素有机密性、完整性、可用性、可控性与可审查性。信息安全的范围包括设备安全、数据安全、内容安全和行为安全。其中数据安全即采取措施确保数据免受未授权的泄露、篡改和毁坏，包括秘密性、完整性和可用性 3 个方面。信息存储安全的范围：信息使用的安全、系统安全监控、计算机病毒防治、数据的加密和防止非法的攻击等。

（2）网络安全。网络安全漏洞和隐患表现在物理安全性、软件安全漏洞、不兼容使用安全漏洞等方面。网络安全威胁表现在非授权访问、信息泄露或丢失、破坏数据完整性、拒绝服务攻击、利用网络传播病毒等方面。安全措施的目标包括访问控制、认证、完整性、审计和保密等 5 个方面。

5.2 信息安全系统的组成框架

【基础知识点】

信息安全系统框架通常由技术体系、组织机构体系和管理体系共同构建。

（1）技术体系。从技术体系看，信息安全系统涉及基础安全设备、计算机网络安全、操作系统安全、数据库安全、终端设备安全等多方面技术。

（2）组织机构体系。信息系统安全的组织机构分为决策层、管理层和执行层 3 个层次。

（3）管理体系。信息系统安全的管理体系由法律管理、制度管理和培训管理 3 个部分组成。

5.3 信息加解密技术

【基础知识点】

1. 数据加密

数据加密是防止未经授权的用户访问敏感信息的手段，保障系统的机密性要素。数据加密有对

称加密算法、非对称加密算法两种。

2. 对称密钥加密算法

对称密钥算法的加密密钥和解密密钥相同，又称为共享密钥算法。对称加密算法主要有：

（1）使用密钥加密的块算法（Data Encryption Standard，DES），明文切分为 64 位的块（即分组），由 56 位的密钥控制变换成 64 位的密文。

（2）三重 DES（Triple-DES）是 DES 的改进算法，使用两把 56 位的密钥对明文做三次 DES 加解密，密钥长度为 112 位。

（3）国际数据加密算法（International Data Encryption Algorithm，IDEA），分组长度 64 位，密钥长度 128 位，已经成为全球通用的加密标准。

（4）高级加密标准（Advanced Encryption Standard，AES），分组长度 128 位，支持 128 位、192 位和 256 位 3 种密钥长度，用于替换脆弱的 DES 算法，且可以通过软件或硬件实现高速加解密。

（5）SM4 国密算法，分组长度和密钥长度都是 128 位。

3. 非对称密钥加密算法

非对称密钥加密算法的加密密钥和解密密钥不相同，又称为不共享密钥算法或公钥加密算法。在非对称加密算法中用公钥加密，私钥解密，可实现保密通信；用私钥加密，公钥解密，可实现数字签名。非对称加密算法可以分为：

（1）RSA（Rivest，Shamir and Adleman）是一种国际通用的公钥加密算法，安全性基于大素数分解的困难性，密钥的长度可以选择，但目前安全的密钥长度已经高达 2048 位。RSA 的计算速度比同样安全级别的对称加密算法慢 1000 倍左右。

（2）SM2 国密算法，基于椭圆曲线离散对数问题，在相同安全程度的要求下，密钥长度和计算规模都比 RSA 小得多。

5.4 密钥管理技术

【基础知识点】

（1）密钥的使用控制。控制密钥的安全性主要有密钥标签和控制矢量两种技术。密钥的分配发送有物理方式、加密方式和第三方加密方式。该第三方即密钥分配中心（Key Distribution Center，KDC）。

（2）公钥加密体制的密钥管理。有直接公开发布（如 PGP）、公用目录表、公钥管理机构和公钥证书 4 种方式。公钥证书可以由个人下载后保存和传递，证书管理机构为 CA（Certificate Authority）。

5.5 访问控制及数字签名技术

【基础知识点】

1. 基本模型

访问控制技术包括 3 个要素，即主体、客体和控制策略。访问控制包括认证、控制策略实现和审计 3 方面的内容。审计的目的是防止滥用权力。

2. 访问控制的实现技术

（1）访问控制矩阵（Access Control Matrix，ACM），以主体为行索引，以客体为列索引的矩阵，该技术是后面三个技术的基础，当主客体元素很多的时候实现困难。

（2）访问控制表（Access Control Lists，ACL），按列（即客体）保存访问矩阵，是目前最流行、使用最多的访问控制实现技术。

（3）能力表（Capabilities），按行（即主体）保存访问矩阵。

（4）授权关系表（Authorization Relations），抽取访问矩阵中的非空元素保存，当矩阵是稀疏矩阵的时候很有效，常用于安全数据库系统。

3. 数字签名

数字签名是公钥加密技术与数字摘要技术的应用。数字签名的条件是：可信、不可伪造、不可重用、不可改变和不可抵赖。基于对称密钥的签名只能在两方间实现，而且需要双方共同信赖的仲裁人。利用公钥加密算法的数字签名则可以在任意多方间实现，不需要仲裁且可重复多次验证。实际应用时先对文件做摘要，再对摘要签名，这样可以大大提升数字签名的速度。同时摘要的泄露不影响文件保密。

5.6 信息安全的抗攻击技术

【基础知识点】

1. 密钥的选择

密钥在概念上被分成数据加密密钥（DK）和密钥加密密钥（KK）两大类。后者用于保护密钥。加密的算法通常是公开的，加密的安全性在于密钥。为对抗攻击，密钥生成需要考虑增大密钥空间、选择强钥和密钥的随机性 3 个方面的因素。

2. 拒绝服务（Denial of Service, DoS）攻击

DoS 是使系统不可访问并因此拒绝合法的用户服务要求的行为，侵犯系统的可用性要素。传统拒绝服务攻击的分类有消耗资源、破坏或更改配置信息、物理破坏或改变网络部件、利用服务程序中的处理错误使服务失效等 4 种模式。

目前常见的 DoS 攻击模式为分布式拒绝服务攻击（Distributed Denial of Service，DDoS）。

现有的 DDoS 工具一般采用 Client（客户端）、Handler（主控端）、Agent（代理端）三级结构。

DoS 的防御包括特征识别、防火墙、通信数据量的统计、修正问题和漏洞 4 种方法。

3. 欺骗攻击与防御

欺骗攻击与防御具体分为：

（1）ARP 欺骗：ARP 协议解析 IP 地址为 MAC 网卡物理地址，欺骗该机制即可阻断正常的网络访问。常用防范办法为固化 ARP 表、使用 ARP 服务器、双向绑定和安装防护软件。

（2）DNS 欺骗：DNS 协议解析域名为 IP 地址，欺骗该机制可以使用户访问错误的服务器地址。其检测有被动监听检测、虚假报文探测和交叉检查查询 3 种方法。

（3）IP 欺骗：攻击者修改 IP 数据报的报头，把自身的 IP 地址修改为另一个 IP，以获取信任。常用防火墙等防范 IP 欺骗。

4. 端口扫描（Port Scanning）

端口扫描是入侵者搜集信息的几种常用手法之一。端口扫描尝试与目标主机的某些端口建立连接，如果目标主机该端口有回复，则说明该端口开放，甚至可以获取一些信息。端口扫描有全 TCP 连接、半打开式扫描（SYN 扫描）、FIN 扫描、第三方扫描等分类。

5. 针对 TCP/IP 堆栈的攻击方式

（1）同步包风暴（SYN Flooding）：是应用最广泛的一种 DoS 攻击方式，攻击 TCP 协议建立连接的三次握手，让目标主机等待连接完成而耗尽资源。可以减少等待超时时间来防范。

（2）ICMP 攻击：例如“Ping of Death”攻击操作系统的网络层缓冲区，旧版操作系统会崩溃死机。防范方法是打补丁、升级到新版操作系统。

（3）SNMP 攻击：SNMP 协议常用于管理网络设备，早期的 SNMP V1 协议缺少认证，可能被攻击者入侵。防范方法是升级 SNMP 协议到 V2 以上并设置访问密码。

6. 系统漏洞扫描

系统漏洞扫描指对重要计算机信息系统进行检查，发现其中可能被黑客利用的漏洞。漏洞扫描既是攻击者的准备工作，也是防御者安全方案的重要组成部分。系统漏洞扫描分为：

（1）基于网络的漏洞扫描，通过网络来扫描目标主机的漏洞，常常被主机边界的防护所封堵，因而获取到的信息比较有限。

（2）基于主机的漏洞扫描，通常在目标系统上安装了一个代理（Agent）或者是服务（Services），因而能扫描到更多的漏洞。有扫描的漏洞数量多、集中化管理、网络流量负载小等优点。

5.7 信息安全的保障体系与评估方法

【基础知识点】

1. 等级保护

《计算机信息系统 安全保护等级划分准则》（GB 17859—1999）规定了计算机系统安全保护能力的 5 个等级。

（1）第 1 级：用户自主保护级（对应 TCSEC 的 C1 级）。

（2）第 2 级：系统审计保护级（对应 TCSEC 的 C2 级）。

（3）第 3 级：安全标记保护级（对应 TCSEC 的 B1 级）。

（4）第 4 级：结构化保护级（对应 TCSEC 的 B2 级）。

（5）第 5 级：访问验证保护级（对应 TCSEC 的 B3 级）。

2. 安全保密技术

安全保密技术主要有：

（1）数据泄密（泄露）防护（Data Leakage Prevention，DLP）。DLP 是通过一定的技术手段，防止企业的指定数据或信息资产以违反安全策略规定的形式流出企业的一种策略。

（2）数字水印（Digital Watermark）。数字水印是指通过数字信号处理方法，在数字化的媒体文件中嵌入特定的标记。水印分为可感知的和不易感知的两种。

3. 安全协议

常用的安全协议有：

（1）SSL 协议。SSL 协议是介于应用层和 TCP 层之间的安全通信协议，提供保密性通信、点对点身份认证、可靠性通信 3 种安全通信服务。

（2）PGP（Pretty Good Privacy）。PGP 是一种加密软件，应用了多种密码技术，包括 RSA、IDEA、完整性检测和数字签名算法，实现了一个比较完善的密码系统。广泛地用于电子邮件安全。

（3）互联网安全协议（Internet Protocol Security，IPSec）。IPSec 是工作在网络层的安全协议，主要优点是它的透明性，提供安全服务不需要更改应用程序。

（4）SET 协议。主要用于解决用户、商家和银行之间通过信用卡支付的交易问题，保证支付信息的机密、支付过程的完整、商户和持卡人身份合法性及可操作性。

（5）HTTPS 协议。详见第 3 小时，这里不再赘述。

4. 信息系统的安全风险与评估

信息系统的安全风险是指由于系统存在的脆弱性所导致的安全事件发生的概率和可能造成的影响。

风险评估是对信息系统及由其处理、传输和存储的信息的保密性、完整性和可用性等安全属性进行科学评价的过程，是信息安全保障体系建立过程中重要的评价方法和决策机制。风险评估的基本要素为脆弱性、资产、威胁、风险和安全措施。其中，威胁是一种对机构及其资产构成潜在破坏的可能性因素或者事件。脆弱性评估是安全风险评估中的重要内容，脆弱性不仅包括各种资产本身存在的脆弱性，没有正确实施的安全保护措施本身也可能是一个安全薄弱环节。风险计算模型包含信息资产、弱点/脆弱性、威胁等关键要素。

5.8 练习题

1．在信息安全领域，基本的安全性原则包括机密性（Confidentiality）、完整性（Integrity）和可用性（Availability）。机密性指保护信息在使用、传输和存储时__（1）__。信息加密是保证系统机

密性的常用手段。使用哈希校验是保证数据完整性的常用方法。可用性指保证合法用户对资源的正常访问，不会被不正当地拒绝。__（2）__就是破坏系统的可用性。

（1）A．不被泄露给已注册的用户　　B．不被泄露给未授权的用户
　　C．不被泄露给未注册的用户　　D．不被泄露给已授权的用户

（2）A．跨站脚本攻击（XSS）　　B．拒绝服务攻击（DoS）
　　C．跨站请求伪造攻击（CSRF）　　D．缓冲区溢出攻击

解析：机密性指保护信息在使用、传输和存储时不被泄露给未授权的用户。

跨站脚本攻击（XSS）是指恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页时，嵌入 Web 中的 html 代码会被执行，从而实现劫持浏览器会话、强制弹出广告页面、网络钓鱼、删除网站内容、窃取用户 Cookies 资料、繁殖 XSS 蠕虫、实施 DDoS 攻击等目的。

拒绝服务（DoS）攻击利用大量合法的请求占用大量网络资源，以达到瘫痪网络的目的。受到 DoS 攻击的系统，可用性大大降低。

跨站请求伪造（CSRF）是一种挟制、欺骗用户在当前已登录的 Web 应用程序上执行非本意的操作的攻击。

缓冲区溢出攻击是指利用缓冲区溢出漏洞，从而控制主机，进行攻击。

答案：B　B

2．DES 加密算法的密钥长度为 56 位，三重 DES 的密钥长度为（　　）位。

A．168　　B．128　　C．112　　D．56

解析：三重 DES 采用两组 56 位的密钥 K1 和 K2，通过“K1 加密—K2 解密—K1 加密”的过程，两组密钥加起来的长度是 112 位。

答案：C

3．非对称加密算法中，加密和解密使用不同的密钥，下面的加密算法中__（1）__属于非对称加密算法。若甲、乙采用非对称密钥体系进行保密通信，甲用乙的公钥加密数据文件，乙使用__（2）__来对数据文件进行解密。

（1）A．AES　　B．RSA　　C．IDEA　　D．DES

（2）A．甲的公钥　　B．甲的私钥　　C．乙的公钥　　D．乙的私钥

解析：加密密钥和解密密钥不相同的算法，称为非对称加密算法，这种方式又称为公钥密码体制。常见的非对称加密算法有 RSA 等。若甲、乙采用非对称密钥体系进行保密通信，甲用乙的公钥加密数据文件，乙使用乙的私钥来对数据文件进行解密。

加密密钥和解密密钥相同的算法，称为对称加密算法。常见的对称加密算法有 DES、3DES、IDEA、AES 等。

答案：B　D